小米 HyperOS 预装运营商 DM 组件数据采集与上报调查报告（公开版）

- 版本：v1.0
- 日期：2026-11-05
- 分析对象：一台 Xiaomi HyperOS 3.0 设备（具体型号、序列号、SIM 信息已隐去）
- 分析方式：静态反编译 + 运行时数据库取证 + 真机抓包 + 解密验证
- 说明：本文已移除全部个人隐私数据，仅保留技术事实与可复现方法

---

0. 摘要

在一台 HyperOS 3.0（Android 16）设备上，确认存在两套运营商终端管理（DM）客户端、一套系统遥测组件和一套本地反诈数据库：

组件	包名	归属	服务器	状态
联通 DM	`com.mobiletools.systemhelper`	中国联通（Xiaomi 平台签名预装）	`dm.wo.com.cn:18080`（HTTP）	活跃，周期上报
移动 DM	`com.miui.dmregservice`	中国移动 / Richinfo	`a.fxltsbl.com:443`（HTTPS）+ CoAP 5683	按需唤醒，心跳正常
系统遥测	`com.miui.misightservice` + `/system_ext/bin/misight`(root)	Xiaomi	`event-log.cnbj1.mi-fds.com`	活跃
本地反诈库	`com.miui.securitycenter`	Xiaomi	未发现上传	本地写入
AI 通	`com.miui.guardprovider`	Xiaomi	`detection-aigc.engine.miui.com` 等	开关关

组件	包名	归属	服务器	状态
话防诈				闭，未启用

主要结论：

1. `SystemHelper` 以 30 分钟为周期采集位置、基站、WiFi，并周期上报设备标识、SIM 标识（部分打码）、经纬度（6 位小数）、行政区、基站参数、WiFi 信息、存储信息，以及全量 App 使用清单。
2. 上报链路为 **明文 HTTP + AES-128-ECB**，且 **AES key = MD5(明文)**；`sign` 参数是 **RSA(1024 位公钥, MD5)**。由于 key 由明文派生，取得本地明文即可还原网络密文（已实测）。
3. `DMRegService` 采集 App 清单、完整 SIM 标识、基站/WiFi、按小时流量（含路由器 MAC 与公网 IP）、蓝牙/WiFi 列表，上报开关由云端配置控制。
4. 两套 DM 均存在 **无权限保护的导出组件**，本机任意应用可重定向上报地址或触发上报。
5. 截屏时间、安装记录、通话记录仅写入本地反诈库，**未发现上传路径**；AI 通话防诈当前关闭。

---

1. 背景

部分小米/HyperOS 机型会随系统预装运营商定制的终端管理（DM）客户端。此类组件通常用于运营商侧的设备注册、网络优化与售后服务，但其数据采集范围、上报频率和加密方式缺少公开说明。

本报告基于一台已 root、已授权 ADB 的自用设备，尝试回答三个问题：

1. 设备上是否存在此类组件？
2. 它们采集什么、发往哪里、如何加密？
3. 用户能否关闭、关闭后是否仍然运行？

---

2. 方法

步骤	工具/手段
组件枚举	`pm list packages`、`dumpsys package`、`dumpsys alarm`、`dumpsys activity exit-info`

步骤	工具/手段
静态分析	`adb pull` 系统 APK → `jadx` 反编译 → 还原采集/加密/上报逻辑
证书分析	`openssl x509` / `openssl rsa`
数据库取证	直接读取 `/data/user/0/*/databases/*.db`、`/data/user_de/0/*/databases/*.db`
网络取证	`tcpdump -i any -w`、`ss -tnp`、`/proc/<pid>/cmdline` 做进程归属
解密验证	依据 `key = MD5(明文)` 重算密钥，与抓包密文逐字节比对，再用 `openssl enc -d -aes-128-ecb` 还原
触发实验	修改采集间隔（已备份并恢复）+ 广播 `BOOT_COMPLETED` 触发上报

取证过程未修改业务数据；测试用配置已恢复原值。

---

3. 发现一：联通 DM（`com.mobiletools.systemhelper`）

3.1 基本信息

项	值
包名	`com.mobiletools.systemhelper`
APK	`/system/priv-app/SystemHelper/SystemHelper.apk`
版本	3.0.1-20260313（versionCode 34，targetSdk 34）
UID	10090
签名	Xiaomi MIUI 平台签名（`O=Xiaomi, OU=MIUI, CN=MIUI`）
内置证书	`assets/pub.cer`，自签名 `O=UNICOM`，RSA 1024 位，序列号 `528B9360`，2019-05-24 → 2119-04-30

项	值
证书指纹	SHA256 81:0C:01:22:BA:6A:F7:A4:B6:A5:92:1F:DB:BB:F9:19:7F:B2:E0:B2:E8:2D:E0:C5:AA:40:D2:8F:1B:7C:65:01

3.2 采集内容

信号/位置（30 分钟一条，本地保留 3 天）

```
Time / IMEI / ICCID / IMSI（部分打码）/ MNC / NetworkType
TAC / CID / PCI / ARFCN / Bands / RSRP / RSRQ / SINR
LONGITUDE / LATITUDE / District
BSSID / SSID
```

App 清单（RegType=A）

每个 App 包含：

```
appLabel / pkgName / runTime / launchCount
tx1 / rx1 / tx2 / rx2 / totalData1 / totalData2 / totalDataWiFi
```

过滤规则：排除 `com.android*`。

在测试设备上，该清单包含系统应用、第三方应用与 root/框架类工具（具体名单已隐去）。这意味着上报内容可用于判断设备是否被 root、安装了哪些工具。

3.3 上报协议

```
POST http://dm.wo.com.cn:18080/register?ver=5.0&model=<MODEL>&manuf=<MANUF>&sign=<RSA>
Content-Type: application/encrypted-json
Content-Length: <AES 密文长度>
User-Agent: Dalvik/2.1.0 (Linux; U; Android <VER>; <MODEL> ...)
```

加密流程：

```
key   = MD5(UTF8(plaintext))
body  = AES-128-ECB/PKCS5(plaintext, key)
sign  = Base64(RSA/ECB/PKCS1(pub.cer, key))
```

- `sign` 并非签名，而是 **RSA 包裹后的 AES key**；服务器用私钥解出 MD5 后解密 body。
- AES-ECB 无 IV，确定性加密：相同明文产生相同密文。
- 域名 CNAME：`63ce5fd2be92dcdf.icloudv6.com` → `223.111.128.82`。

3.4 队列与重试

- 本地库：`/data/user/0/com.mobiletools.systemhelper/databases/systemhelper`（表 `dmregister`）
- 队列封顶约 10 条；HTTP 200/416 视为成功，其他状态（含 429）把明文写入队列
- 成功后会启动历史重试线程，弹出最新一条重发；该线程先删除后发送，失败即丢
- 实测队列规模约 10–11 条、约 187 KB，其中单条最大约 66–69 KB

3.5 触发条件

```
if (Settings.Secure.getInt("operator_service_improve_plan", 0) != 1) return false;
if (!networkConnected()) return false;
return (isWifi && mnc.startsWith("460")) || (!isWifi && isUnicom);
```

3.6 抓包/解密结果（脱敏）

包	密文字节	响应	结果
B（设备信息）	1,024	429	解密成功
R（信号历史）	68,784	429	**解密成功，100 条记录**
A（App 清单）	40,464	200	成功发出，本地无明文（不可从包解密）
A（App 清单）	40,464	**429**	**解密成功，169 个 App**

> A 包的 200 样本无法解密（成功不落库）；通过连续触发制造限流（429）后，同一明文会写入本地队列，即可完成“密文 → 明文”闭环。

R 包解密后的统计（不含具体值）：

- 记录数：100
- 覆盖约 2.3 天，30 分钟一条
- 基站：4 个 CID、3 个 PCI
- WiFi：2 个 SSID
- 经纬度：集中在约 100m × 20m 范围内
- 行政区：单一城区

A 包解密后的统计（不含具体值）：

- 记录数：169 个 App
- 字段：应用名、包名、使用时长、启动次数、移动/WiFi 收发
- 过滤：排除 `com.android*`
- 同一时段连续请求中，服务器返回 `200` 与 `429` 混合

3.7 无权限保护的导出组件

类型	组件	风险
service	`.service.RegisterHelperService`	AIDL 可改 serverAddress、改间隔、删配置、开关日志
activity	`.Activity.TestActivity`	打开即显示完整设备信息 JSON
receiver	`.control.OnBootReceiver`	任意应用可触发上报
receiver	`.control.SIMStateReceiver`	任意应用可触发
receiver	`.control.ConnectStateReceiver`	任意应用可触发

`IRegisterHelperService` 的方法：

```
c(String addr);  // 修改上报服务器
```

```
a(int ms);       // 修改采集/上报间隔
e();             // 删除配置
d(boolean on);   // 开关日志
b();             // 读日志开关
```

实现中没有 `getCallingPackage()` 或权限校验，任意本机应用均可绑定调用。

---

4. 发现二：移动 DM（`com.miui.dmregservice`）

4.1 基本信息

项	值
包名	`com.miui.dmregservice`
APK	`/product/priv-app/RegService/RegService.apk`
版本	15.0.9
UID	1001（radio）
签名	Xiaomi MIUI 平台签名
开发方	Richinfo（`cn.richinfo.*`）

4.2 数据库

`/data/user_de/0/com.miui.dmregservice/databases/cmcc_dm.db`

表	内容
`app_info_*`	包名、UID、flags、启动次数、使用时长、移动/WiFi 收发
`table_name_network`	完整 IMSI、ICCID、cellid、lac、BSSID、SSID、band、RSRP、SINR、运营商

表	内容
`table_of_time_related_traffic`	每小时流量、路由器 MAC、公网 IP
`table_name_battery_charge`	电量/温度/状态
`table_name_wifi_list` / `table_name_bluetooth`	WiFi/蓝牙扫描列表
`table_app_collect_list`	采集窗口与 SIM 标识

预装清单：`key_pre_install_info` 存有约 393 个预装 App 的元数据（名称、包名、版本、安装时间、签名 MD5、flags），尚未上报。

4.3 云端开关

开关	值
APP_REPORT_SWITCH	Y
key_network_report_switch	Y
KEY_TIME_RELATED_TRAFFIC_SWITCH	Y
key_wifi_list_report_switch	Y
key_bluetooth_report_switch	Y
key_heartbeat_switch	Y
key_pre_installed_report_switch	N
KEY_SANPSHOT_REPORT_SWITCH	N
key_battery_charging_report_switch	N
key_5g_state_report_switch	N

周期：心跳 24 小时；App 采集 7 天；24 小时最多 5 次。

4.4 网络

- 主通道：`https://a.fxltsbl.com` → `117.134.71.39:443`（TLS）
- 备用：`https://b.fxltsbl.com`
- CoAP/LwM2M：`coap://m.fxltsbl.com:5683` → `117.134.71.81`（本机未观察到流量）
- 实名拍照：`https://auc.fxltsbl.com/AuthCenter/datareport?func=tsdk:photoReg`
- AES key 硬编码于 `Constant.java`

4.5 运行特征

- 未唤醒时静默（进程被系统回收、无闹钟）
- 收到 `cn.richinfo.dmyk.action.HEARTBEAT` 后立即启动，建立 2 条 TLS 连接，上传约 2.3 KB，收到约 0.3 KB
- `last_success_heartbeat_time` 随之更新，App 采集窗口同步延长

4.6 无权限保护的导出组件

类型	组件	风险
service	`cn.richinfo.dm.service.DMService`	任意应用可 startService 触发 DM 流程
receiver	`com.richinfo.mthttp.MTStaticBReceiver`	任意应用可发送 `alarm_heart`/`alarm_retry` 触发心跳
receiver	`.BootCompleteReceiver`	任意应用可触发

---

5. 发现三：系统遥测（MiSight）

项	值
守护进程	`/system_ext/bin/misight`（**uid=0 root**）
App	`com.miui.misightservice`（0.9.5，`/system_ext/app/MiSightService`）

项	值
本地库	`onetrack` / `one_track_cloud` / `onetrack_cache`
配置/策略	`https://event-log.cnbj1.mi-fds.com/event-log/...`
上传模式	`autoupload`，JobScheduler 周期 480 分钟
采集类别（云端配置）	application / audio_video / bluetooth / camera / cellular / charge / component / display / fingerprint / framework / gps / misight / network 等

取证时 `events` 表为空，未观察到大批量数据外发；主要行为是拉取配置与策略。

---

6. 发现四：本地反诈库（`com.miui.securitycenter`）

数据库：`/data/misc/user/0/securitycenter/fraud_detection_data.db`

表	说明
`screenshot`	仅毫秒时间戳（字段名拼写错误 `screenshort_time`）
`install_app`	包名、来源、版本、安装完成时间
`fraud_phone`	号码 MD5、归属地、运营商、时长
`call_forwarding`	呼叫转移状态
`voip_record` / `screen_share`	通话/投屏记录
`airplane_mode` / `fraud_url`	飞行模式/URL 记录

- 写入进程：`com.miui.securitycenter.remote`（uid 1000）
- 对外接口：`FraudDetectionProvider` / `MiFraudDetectionService`，权限为 signature 级（`ACCESS_XSOF_FRAUD_DETECTION`）
- 实测：按一次截屏，`screenshot` 表 +1 行，毫秒时间戳
- **未发现上传路径**：数据为 `Parcelable`，无网络 DTO；`fraud-detection.engine.miui.com` 在 SecurityCenter

中仅用于 NFC 反诈配置 GET

---

7. 发现五：AI 通话防诈（`com.miui.guardprovider`）

- 权限：`CAPTURE_AUDIO_OUTPUT` / `CAPTURE_VOICE_COMMUNICATION_OUTPUT` / `CAPTURE_VIDEO_OUTPUT` / `MANAGE_MEDIA_PROJECTION` 均为 install granted
- 代码证据：
- `p079l1/d.java`：通过反射获取 `MediaProjectionManager.mService`，直接调用 `createProjection`，绕过系统授权弹窗
- `p079l1/a.java`：`MediaRecorder` 720×1280 / 24 fps / 1 Mbps 录屏
- `AiGuardService.C()`：`clip.mp4` → Base64 → `detection-aigc.engine.miui.com`
- 状态：`ai_guard_function_switch = 0`，`ai_guard_function_available = false`，GuardProvider 进程未运行，`RECORD_AUDIO` 运行时权限未授予，`voip_record/screen_share` 为空
- 结论：**能力存在，未启用**

---

8. 安全与合规问题

1. **明文 HTTP 传输元数据**：请求走 `http://`，URL、机型、厂商、时间、大小、`sign` 可被中间人观察。
2. **弱加密设计**：AES-128-ECB、无 IV、`key = MD5(明文)`，确定性加密；相同明文产生相同密文。
3. **1024 位 RSA + 100 年有效期**：自签名证书，2019–2119；结构正常（popcount 49.7%，无小因子、无共享素数、无近似素数），但 1024 位已低于现代标准。
4. **无权限保护的导出组件**：任意本机应用可修改 `SystemHelper` 的上报服务器、触发上报、清空配置；可启动移动 DM 服务、触发心跳。
5. **可观测性缺失**：两套 DM 均无用户可见开关/日志；`operator_service_improve_plan` 是唯一总闸。
6. **加密可逆性**：由于 key 由明文派生，任何能获取本地明文（root、备份、队列）的一方都可解密网络流量。

---

9. 隐私影响（定性）

可被还原的画像维度：

维度	内容
设备身份	设备标识、SIM 标识、机型、系统、存储
位置	经纬度、行政区、基站、WiFi、路由器公网 IP
行为	每个 App 的使用时长、启动次数、流量
安装	安装来源、版本、安装时间、部分签名
截屏	毫秒时间戳（仅本地）
Root/框架	可识别 root 与框架类工具

两套 App 清单合并后，可判断设备的 root 状态、常用应用、作息与位置轨迹。

---

10. 建议

10.1 用户侧（可逆）

```
# 1) 关闭运营商服务改进计划（总闸）
adb shell settings put secure operator_service_improve_plan 0

# 2) 清空待传队列
adb shell su -c 'rm -f /data/user/0/com.mobiletools.systemhelper/databases/systemhelper*'
adb shell su -c 'rm -f /data/user/0/com.mobiletools.systemhelper/databases/signalhelper*'
adb shell su -c 'rm -f /data/user_de/0/com.miui.dmregservice/databases/cmcc_dm.db*'

# 3) 停用组件（会影响运营商相关功能，建议先做 1+2）
adb shell su -c 'pm disable-user --user 0 com.mobiletools.systemhelper'
adb shell su -c 'pm disable-user --user 0 com.miui.dmregservice'

# 4) 域名封堵：dm.wo.com.cn / a.fxltsbl.com / m.fxltsbl.com / auc.fxltsbl.com
```

10.2 厂商/运营商侧

- DM 通道改为 HTTPS，或至少使用 AEAD（AES-GCM）与随机 IV；
- 停止使用 `key = MD5(明文)`，改为标准密钥协商；
- 升级到 ≥2048 位 RSA 并缩短证书有效期；
- 为导出组件增加 signature 权限与调用方校验；
- 提供用户可见的开关、数据清单与删除入口；
- 明确告知预装 DM 客户端的存在与采集范围。

---

11. 附录：IOC

域名 / IP

```
dm.wo.com.cn:18080            → 223.111.128.82 (CNAME 63ce5fd2be92dcdf.icloudv6.com)
a.fxltsbl.com:443             → 117.134.71.39
b.fxltsbl.com:443
m.fxltsbl.com:5683            → 117.134.71.81 (CoAP)
auc.fxltsbl.com:443
event-log.cnbj1.mi-fds.com:443
```

包名 / 路径

```
com.mobiletools.systemhelper   /system/priv-app/SystemHelper/SystemHelper.apk
com.miui.dmregservice          /product/priv-app/RegService/RegService.apk
com.miui.misightservice        /system_ext/app/MiSightService
com.miui.securitycenter        /data/misc/user/0/securitycenter/fraud_detection_data.db
com.miui.guardprovider         /product/app/MIUIGuardProvider
```

核查命令

```
adb shell pm path com.mobiletools.systemhelper
adb shell dumpsys package com.mobiletools.systemhelper | grep -E "versionName|appId|codePath"
adb shell settings get secure operator_service_improve_plan
adb shell su -c 'sqlite3 /data/user/0/com.mobiletools.systemhelper/databases/systemhelper \
```

```
  "select ID, length(jsonString) from dmregister"'
adb shell ss -tnp | grep -E "18080|:443"
```

11.1 证据包（v1.2）

完整证据随报告仓库提供：

```
evidence/
├── MANIFEST.md                 # 每个文件的 SHA-256
├── SHA256SUMS                  # 可直接 sha256sum -c 校验
├── apk/                        # 4 个 APK（本地保留，不入库）
├── decompiled/
│   ├── key/                     # 48 个关键类源码（入库）
│   └── full/                    # 完整 jadx 源码树（本地保留）
├── certificates/               # pub.cer / pub.pem / openssl 文本
├── databases/                  # 仅 schema 与行数
└── redacted/                   # 脱敏样本
```

> 原始 pcap 仅本地保留（`private/pcap/`），不入库。

校验：

```
sha256sum -c evidence/SHA256SUMS
```

> 原始数据库、解密后的 CSV/JSON、含隐私的内部报告均在 `private/`，不随公开仓库分发。

---

12. 限制与声明

- 本报告基于单台设备、单次取证，不代表所有小米机型/系统版本。
- 反编译代码可能因混淆存在偏差，关键结论均已通过运行时数据与抓包交叉验证。
- 取证过程未修改业务逻辑；测试用配置已恢复原值。
- 本文已移除设备标识、SIM 标识、位置、WiFi、App 清单等个人隐私信息，仅保留技术事实。

- 文中所述组件均为系统预装、Xiaomi 平台签名，不代表其具有恶意意图；报告关注的是采集范围、加密方式与用户可控性。